Audit Header Keamanan & Matriks Akses per Peran

Daftar Isi

0. Ringkasan
1. Cara mengulang audit ini
2. Header yang diamati (permintaan nyata)
   2.1 Situs publik — GET / → 200
   2.2 Dashboard — GET /
3. Kontrol negatif (dijalankan untuk keenam peran)
4. Matriks akses halaman (status HTTP nyata)
5. Matriks kapabilitas (dari src/roles.py, satu sumber)
   5.1 Siapa memegang kapabilitas apa
   5.2 Tangga persetujuan & pemisahan tugas
6. Temuan terperinci
   F1 — HSTS tidak ada (sedang) · sudah diperbaiki
   F2 — Kebijakan MFA tidak tersambung ke permukaan yang berjalan (sedang)
   F3 — Permissions-Policy / COOP / CORP tidak ada (rendah)
   F4 — Halaman form di-cache publik (rendah)
   F5 — robots.txt dan sitemap.xml 404 (rendah, SEO)
   F6 — Yang sudah baik (jangan diubah tanpa alasan)
7. Batas audit ini (jujur)
Lampiran A — scripts/access_matrix_probe.py

Tanggal: 2026-10-25 · **Kode diuji:** `7c7bc96` · **Metode:** server nyata + HTTP nyata, bukan pembacaan dokumen **Lingkup:** dua permukaan yang berjalan — situs publik (`marketing_site.py`) dan dashboard internal (`dashboard.py`) **Di luar lingkup:** konfigurasi TLS riil, WAF, uji beban, sertifikat, HSTS preload

---

0. Ringkasan

#	Temuan	Tingkat	Status setelah audit
F1	**HSTS tidak ada** di kedua contoh konfigurasi nginx	sedang	**diperbaiki** di `docs/DEPLOYMENT.md` §4.1/§4.2
F2	**`identity.py` (MFA wajib untuk owner/finance/gm) tidak diimpor siapa pun**; permukaan nyata memakai token bearer statis tanpa MFA dan tanpa kedaluwarsa	sedang	**diperbaiki (A+B)**: sesi operator per orang + TTL + pencabutan + audit; token mesin tetap, dengan jadwal rotasi 90 hari — sisa risiko di §6 F2
F3	`Permissions-Policy`, `COOP`, `CORP` tidak dikirim	rendah	diterima; CSP sudah menutup skrip dan framing
F4	Halaman form `/inquiry` di-cache publik 300 s	rendah	diterima; diverifikasi tidak ada token/data per pengguna di halaman itu

#	Temuan	Tingkat	Status setelah audit
F5	`/robots.txt` dan `/sitemap.xml` → 404	rendah (SEO, bukan keamanan)	dicatat
F6	Header aplikasi lain (CSP, XFO, nosniff, no-store, Server)	—	**lulus**, bukti di §2

Angka pokok: **72/72 sel matriks akses sesuai niat kode**, **3/3 kontrol negatif menolak**, **0 kebocoran versi** di header `Server`.

---

1. Cara mengulang audit ini

```
# 1. Salinan DB — jangan pernah memakai data/villa.db untuk pengujian
cp data/villa.db /tmp/villa_hdr_dash.db

# 2. Jalankan kedua permukaan di loopback
python3 src/marketing_site.py --db /tmp/villa_hdr_mkt.db --port 8897 &
python3 src/dashboard.py     --db /tmp/villa_hdr_dash.db --port 8898 --token audit-token-xyz &

# 3. Header
curl -sS -D - -o /dev/null http://127.0.0.1:8897/
curl -sS -D - -o /dev/null -H "Authorization: Bearer audit-token-xyz" http://127.0.0.1:8898/

# 4. Matriks: 6 peran × 12 rute, ditambah kontrol negatif
python3 scripts/access_matrix_probe.py --db /tmp/villa_hdr_dash.db --json /tmp/access_matrix.json
```

Semua pengujian memakai salinan DB di `/tmp`; tidak ada tulisan ke `data/villa.db`. Skrip probe **menolak** berjalan bila `--db` menunjuk `data/villa.db`.

---

2. Header yang diamati (permintaan nyata)

2.1 Situs publik — `GET /` → 200

Header	Nilai	Penilaian
`Server`	`VillaMarketing/1.0`	baik — tanpa versi Python
`Content-Security-Policy`	`default-src 'self'; style-src 'unsafe-inline'; img-src 'self' data:; form-action 'self'; frame-ancestors 'none'; base-uri 'self'`	kuat; `'unsafe-inline'` hanya untuk gaya, tidak ada `<script>` di template (diverifikasi: 0 hasil)
`X-Frame-Options`	`DENY`	baik, berlapis dengan `frame-ancestors 'none'`
`X-Content-Type-Options`	`nosniff`	baik
`Referrer-Policy`	`strict-origin-when-cross-origin`	baik
`Cache-Control`	`public, max-age=300` (200) · `no-store` (404)	sesuai; tidak ada data per pengguna
`X-Robots-Tag`	`noindex` pada 404	baik

Header	Nilai	Penilaian
`Strict-Transport-Security`	**tidak ada**	F1 — tidak bisa dari aplikasi (upstream HTTP), wajib di proxy
`Permissions-Policy` / `COOP` / `CORP`	tidak ada	F3
`Set-Cookie`	tidak ada	baik — tidak ada sesi untuk dibajak

2.2 Dashboard — `GET /`

Header	Nilai	Penilaian
`Server`	`VillaAgencyDashboard/1.0`	baik — tanpa versi Python
`Content-Security-Policy`	`default-src 'none'; style-src 'unsafe-inline'; form-action 'self'; frame-ancestors 'none'; base-uri 'none'`	kuat — `default-src 'none'` mematikan seluruh pemuatan
`X-Frame-Options`	`DENY`	baik
`X-Content-Type-Options`	`nosniff`	baik
`Referrer-Policy`	`no-referrer`	baik (lebih ketat dari situs publik)
`Cache-Control`	`no-store`	baik — halaman internal tidak boleh tersimpan
`WWW-Authenticate`	`Bearer realm="villa-dashboard"` pada 401	baik
`Connection`	`close`	baik — tidak ada koneksi persisten untuk disalahgunakan
`Strict-Transport-Security`	**tidak ada**	F1

---

3. Kontrol negatif (dijalankan untuk keenam peran)

Uji	Harapan	Hasil
Tanpa token	401	**401 untuk 6/6 peran**
Token palsu (`Bearer token-palsu`)	401	**401 untuk 6/6 peran**
Token peran rendah + header `X-Role`/`X-Actor-Role`/`X-Dashboard-Role: owner` ke `/finance`	403 (peran tidak boleh dinaikkan lewat header klien)	**403 untuk 6/6 peran**

Ini membuktikan kalimat di docstring modul (“identity is never taken from the request”) bukan sekadar klaim: peran hanya datang dari token.

---

4. Matriks akses halaman (status HTTP nyata)

Halaman	reservation	finance	operations	owner	auditor	gm
command_center `/`	200	200	200	200	200	200

Halaman	reservation	finance	operations	owner	auditor	gm
cases `/cases`	200	**403**	200	200	200	200
inventory `/inventory`	200	**403**	200	200	**403**	**403**
finance `/finance`	**403**	200	**403**	200	**403**	200
operations `/operations`	200	**403**	200	200	**403**	**403**
approvals `/approvals`	200	200	200	200	200	200
properties `/properties`	200	200	200	200	200	200
marketing `/marketing`	200	**403**	200	200	200	**403**
channels `/channels`	200	**403**	200	200	**403**	**403**
shadow_eval `/shadow_eval`	**403**	**403**	200	200	200	**403**
outbox `/outbox`	**403**	**403**	200	200	200	**403**
audit `/audit`	**403**	**403**	**403**	200	200	200

Ringkas: reservation 8 halaman · finance 4 · operations 10 · owner 12 · auditor 8 · gm 6.

Kesesuaian dengan kode: dibandingkan sel per sel terhadap `dashboard.PAGE_ROLES` → **72 sel diuji, 0 tidak cocok**. Deny-by-default terbukti: halaman yang tidak terdaftar untuk suatu peran menghasilkan 403, bukan 200.

Catatan yang perlu dibaca, bukan disembunyikan:

- **`auditor` tidak boleh membuka `inventory`, `operations`, `channels`** — auditor hanya melihat kasus, keuangan, marketing, shadow-eval, outbox, audit. Itu sesuai `PAGE_ROLES`, tetapi berarti auditor tidak bisa memeriksa klaim operasional yang mendasari angka keuangan.
- **`gm` tidak boleh membuka `cases`, `inventory`, `operations`, `marketing`, `channels`, `outbox`** — GM ada di jalur uang (lihat §5), tetapi tidak bisa melihat antrean kasus atau inventori. Ini keputusan produk yang perlu dikonfirmasi owner, bukan bug.
- **`reservation` boleh membuka `approvals`** dan termasuk `WRITE_ROLES`, tetapi perannya dipetakan ke `reservation_agent` (rank 1) — lihat §5.

---

5. Matriks kapabilitas (dari `src/roles.py`, satu sumber)

5.1 Siapa memegang kapabilitas apa

Kapabilitas	Pemegang
`ai.control`	owner, system_admin
`approve.money_out`	finance_manager, gm, owner
`approve.pricing`	reservation_manager, owner
`make.money_out`	**(tidak ada)**
`finance.read` / `finance.write`	finance_manager
`booking.write` / `operations.write`	reservation_manager
`stays.read`	reservation_manager, greeting_service
`notes.write`	greeting_service
`audit.read`	auditor, gm, owner
`system.write`	system_admin

Kapabilitas	Pemegang
`commercial.write`	commercial_manager
`partnership.write`	partnership_manager
`revenue.read`	revenue_manager
`legal.record`	legal_compliance
`report.read`	gm, owner, revenue_manager

5.2 Tangga persetujuan & pemisahan tugas

Atribut	Nilai
Rank	`reservation_agent` 1 · `reservation_manager` 2 · `finance_manager` 3 · `gm` 4 · `owner` 5
MFA wajib	owner, finance_manager, gm
Approver uang keluar	finance_manager, gm, owner
Adjudikator	reservation_agent, reservation_manager, finance_manager, gm, owner

Tiga hal yang diverifikasi, bukan diasumsikan:

1. **`make.money_out` tidak punya pemegang.** `tests/test_roles.py` menegaskan owner pun bukan maker — maker memang disediakan untuk principal AI yang belum diberi kapabilitas. Konsekuensinya: saat ini tidak ada manusia yang bisa *membuat* perintah uang keluar; hanya bisa menyetujui yang sudah ada.
2. **`finance_staff` dan `reservation_agent` kosong kapabilitas** — sesuai ADR-0035 §3 (keduanya dihapus sebagai peran manusia, disediakan untuk layanan AI). Ini **bukan** drift dokumen.
3. **`system_admin` tanpa MFA** meski memegang `system.write` dan `ai.control`. ADR-0035 memberinya nol otoritas bisnis/keuangan, jadi ini konsisten dengan pembagian kekuasaan — tetapi `system.write` tetap mampu mengubah konfigurasi, sehingga MFA untuk peran ini layak dipertimbangkan saat go-live.

---

6. Temuan terperinci

F1 — HSTS tidak ada (sedang) · sudah diperbaiki

Tidak ada satu pun berkas di repo yang memuat `Strict-Transport-Security` (pencarian menyeluruh: 0 hasil), padahal kedua contoh nginx memakai `listen 443 ssl`. Tanpa HSTS, kunjungan pertama masih bisa diturunkan ke HTTP.

Perbaikan: `docs/DEPLOYMENT.md` §4.1 dan §4.2 kini memuat `add_header Strict-Transport-Security "max-age=31536000; includeSubDomains" always;` plus `ssl_protocols TLSv1.2 TLSv1.3;` dan `server_tokens off;`. Catatan penting yang ikut ditulis: `add_header` di dalam `location` **menggantikan** header selevel `server`, jadi HSTS harus ditulis di blok yang sama dengan header lain atau diwarisi dengan sadar.

HSTS **tidak** bisa dipasang di aplikasi: upstream berjalan HTTP, dan header HSTS yang dikirim lewat HTTP diabaikan peramban.

F2 — Kebijakan MFA tidak tersambung ke permukaan yang berjalan (sedang)

`src/identity.py` menyatakan “MFA wajib untuk OWNER dan FINANCE”, mendefinisikan `MFA_REQUIRED_ROLES`, sesi, dan faktor kedua. Saat audit itu **tidak dipakai** oleh kode mana pun:

```
grep -rn "import identity" src/ scripts/   → 0 hasil (saat audit)
```

Perbaikan (A+B, 2026-10-29):

- `dashboard.py` sekarang menerima **sesi operator** di samping token mesin. Token sesi diselesaikan oleh `identity.SessionService`: identitas dan peran dibaca dari baris sesi, bukan dari header. Peran kanonik dipetakan ke enam peran halaman lewat `PAGE_ROLE_BY_CANONICAL`; peran tanpa halaman (`system_admin`) **ditolak**, tidak diperluas.
- `scripts/session_token.py` menjadi alat resmi: `enroll`, `confirm`, `login`, `list`, `revoke`, `rotate`. Login menulis `auth_events` (LOGIN/ACCESS_DENIED/SESSION_REFUSED).
- Batas waktu berlaku: idle 30 menit, absolut 12 jam (dari `identity`), dan pencabutan berlaku pada permintaan berikutnya (diuji: 401 seketika).
- Token mesin statis tetap ada untuk cron/integrasi, kini dengan **jadwal rotasi 90 hari** yang ditulis di `docs/security/SESSION_AUTH.md` §4.

Bukti: `tests/test_dashboard_sessions.py` — 11 tes (pemetaan peran, MFA wajib untuk owner, sesi dicabut, idle, absolut, peran tanpa halaman, token statis tetap jalan, token asing, jejak `auth_events`). Uji HTTP nyata: sesi owner → `/finance` 200, sesi auditor → `/audit` 200 dan `/finance` 403, setelah `revoke` → 401.

Sisa risiko yang tidak disembunyikan: platform tidak punya faktor kata sandi. Sesi dibuka dengan menyatakan identitas + kode TOTP; siapa pun yang bisa menjalankan CLI sudah bisa membaca database. Yang ditambahkan adalah akuntabilitas, kedaluwarsa, dan pencabutan — bukan pertahanan terhadap penyerang lokal. Dashboard tetap hanya untuk loopback/VPN. Bila kelak dibuka ke internet, login berlapis (kata sandi + TOTP untuk **semua** peran) menjadi syarat baru, bukan peningkatan opsional.

F3 — `Permissions-Policy` / `COOP` / `CORP` tidak ada (rendah)

Dengan CSP `default-src 'none'` (dashboard) dan `default-src 'self'` (publik), tidak ada jalur pemuatan yang bisa disalahgunakan hari ini. Header ini mencegah fitur peramban (kamera, mikrofon, geolokasi) dan isolasi proses aktif tanpa diminta. Belum ditambahkan karena tidak ada fitur yang membutuhkannya — dicatat agar tidak diklaim “sudah lengkap”.

F4 — Halaman form di-cache publik (rendah)

`GET /inquiry` → `Cache-Control: public, max-age=300`. Aman karena halaman itu tidak memuat token CSRF dan tidak memuat data pengguna (diverifikasi: tidak ada `<input>` tersembunyi bertoken; proteksi form memakai pemeriksaan `Origin` + pembatas laju). Bila kelak ada token di halaman form, cache ini harus menjadi `no-store`.

F5 — `robots.txt` dan `sitemap.xml` 404 (rendah, SEO)

Bukan masalah keamanan, tetapi situs publik tanpa keduanya sulit dirayapi dengan benar. Dicatat sebagai item produk.

F6 — Yang sudah baik (jangan diubah tanpa alasan)

- `Server` tidak membocorkan versi Python di kedua permukaan.
- Tidak ada cookie sama sekali → tidak ada `HttpOnly`/`SameSite`/`Secure` yang bisa salah set.
- Dashboard mengirim `no-store` dan `no-referrer`, lebih ketat dari situs publik.
- 401 mengirim `WWW-Authenticate` yang benar; 405 mengirim `Allow`.
- `Connection: close` pada dashboard sesuai desain single-threaded (satu koneksi sqlite per thread).

---

7. Batas audit ini (jujur)

- **Tidak** menguji TLS sungguhan: tidak ada sertifikat, cipher, OCSP, atau uji downgrade. HSTS hanya diperbaiki di dokumentasi konfigurasi, bukan dibuktikan hidup.

- **Tidak** menguji WAF, DDoS, atau pembatasan laju di edge.
- **Tidak** menguji dashboard di belakang proxy nyata (header `X-Forwarded-For` dan `Host` diasumsikan sesuai contoh di `DEPLOYMENT.md`).
- **Tidak** menguji beban; server dashboard memang single-threaded dan tidak dirancang untuk konkurensi.
- Matriks peran diuji pada **satu instance per peran**; tidak ada uji multi-agen atau pergantian peran di tengah sesi (memang tidak didukung oleh desain token statis).

Lampiran A — `scripts/access_matrix_probe.py`

Skrip ini ikut di-commit supaya audit bisa diulang pembeli tanpa menulis ulang alatnya.

1. Untuk setiap peran di `dashboard.ROLES`: buka koneksi sqlite baru **di dalam thread pelayan** (sqlite3 terikat ke thread pembuatnya), panggil `create_app(..., tokens=...)`, sajikan di port acak loopback.
2. Minta 12 rute dengan token peran itu; catat status.
3. Kontrol negatif: tanpa token, token palsu, dan `/finance` memakai token peran rendah + tiga header peran palsu.
4. Bandingkan sel per sel terhadap `PAGE_ROLES`; cetak jumlah ketidakcocokan dan exit code `0` (bersih) atau `2` (ada yang menyimpang). Log permintaan dashboard dialihkan ke stderr agar stdout tetap bisa diparse.

Hasil yang diarsipkan: **72 sel, 0 tidak cocok**, kontrol `{tanpa_token: 401, token_palsu: 401, eskalasi_header: 403}`.